

NOM	ARBAU
Prénom	Marc-antoine
Date de naissance	27/04/2004

Copie à rendre

TP – Développeur Web et Web Mobile

Documents à compléter et à rendre

Lien du git : <https://github.com/jumeaux227-debug/ECF-Vite-et-Gourmand>

Lien de l'outil de gestion de projet :

<https://trello.com/invite/b/69ca51fcbf8a5878a0793c87/ATTlea08eed25f19763642d9faa41b4caff6B8FE9A4C/ecf-final-version>

Lien du déploiement :

Login et mot de passe administrateur : admin@gmail.com / admin12345

SANS CES ELEMENTS, VOTRE COPIE SERA REJETEE

Partie 1 : Analyse des besoins

1. Effectuez un résumé du projet en français d'une longueur d'environ 20 lignes soit 200 à 250 mots

Le projet consiste en la conception et le développement d'une application web dynamique et responsive les chefs gastronomique Julie & José.

L'objectif principal est de moderniser la gestion de leur établissement tout en offrant une vitrine numérique interactive et accessible à leur clientèle.

Développée en architecture MVC avec le langage PHP pour la logique métier et une base de données relationnelle MySQL, l'application intègre un catalogue de menus avec un système de filtrage dynamique (filtrage par thèmes, régimes alimentaires, nombre de convives et prix). Côté administration, l'interface propose un suivi strict des droits grâce à une gestion des rôles (Administrateur, Employé, Client). Le système intègre des modules essentiels tels que la gestion des stocks, un tableau de bord de gestion des ressources humaines (RH), ainsi qu'un espace de modération des avis clients.

Pour répondre aux exigences modernes, l'application est couplée à un sous-système analytique NoSQL, permettant l'extraction et la visualisation de statistiques avancées sur les comportements d'achat. Enfin, une attention a été portée à la sécurité (hachage des mots de passe), à la conformité réglementaire (RGPD, mentions légales) et à l'accessibilité numérique (RGAA).

2. Exprimez le cahier des charges, l'expression du besoin ou les spécifications fonctionnelles du projet

Analyse de la demande

- **À qui le système rend-il service ?** Aux clients de la pâtisserie fine, aux chefs cuisiniers (Julie & José) ainsi qu'à leur personnel (employés).

- **Sur quoi le système agit-il ?** Sur la gestion des menus, le suivi des stocks de pièces rôties, la planification interne (RH), la récolte des avis clients et l'analyse de données statistiques (NoSQL).
- **Dans quel but ?** Moderniser l'activité commerciale de l'établissement en proposant un outil de commande en ligne responsive, tout en automatisant la gestion administrative et analytique en arrière-plan.

Contexte et Objectifs du Projet

- **Accroître le chiffre d'affaires** en permettant aux clients de consulter les formules gastronomiques et de préparer leurs commandes à l'avance.
- **Optimiser les pertes** grâce à un système strict de suivi des stocks en temps réel (quantités de commandes restantes).
- **Piloter l'activité** grâce à un tableau de bord analytique basé sur des technologies Big Data / NoSQL pour cibler les tendances de consommation.

Spécifications Fonctionnelles

Spécifications de l'Espace Public & Profil Client

- **Consultation du catalogue (Responsive)** : Interface ergonomique permettant de visualiser la carte gastronomique.
- **Filtrage dynamique (sans rechargement de page)** : Possibilité de filtrer instantanément les menus selon 4 critères : le thème (ex: Tradition, Événement), le régime alimentaire (ex: Standard, Végétarien), le nombre de convives minimum, et le prix maximum par personne.
- **Espace Client authentifié** : Création de compte et connexion sécurisée permettant d'accéder à l'historique des commandes passées.
- **Retour d'expérience** : Possibilité pour le client de soumettre un avis ou une note concernant une prestation, alimentant le module de réputation.

Spécifications de l'Espace Employé & Modérateur

- **Tableau de bord de gestion (Espace Employé)** : Consultation des commandes actives et mise à jour des statuts de préparation des rôtisseries.
- **Modération des avis** : Interface dédiée permettant de valider ou de rejeter les commentaires soumis par les clients avant leur publication sur l'espace public (protection de l'image de marque).

Spécifications de l'Espace Administrateur

- **Contrôle Global (Panel Admin)** : Gestion complète des comptes utilisateurs (création, modification des rôles, bannissements).
- **Gestion des Ressources Humaines (RH)** : Module de suivi du personnel, des plannings de la rôtisserie ou des fiches de postes.
- **Analytique NoSQL (Stats NoSQL)** : Intégration d'un module d'extraction de données complexes pour générer des indicateurs clés de performance (KPI) sur les ventes et l'état des stocks.

Spécifications Techniques et Contraintes Non-Fonctionnelles

- **Sécurité** : Chiffrement obligatoire des mots de passe en base de données à l'aide de l'algorithme . Protection contre les injections SQL via l'utilisation systématique de requêtes préparées avec PDO.

- **Conformité RGPD** : Présentation obligatoire d'une page de Mentions Légales et d'une Politique de Confidentialité explicitant le traitement des données personnelles (emails des comptes).
- **Performance et Portabilité** : Code source léger structuré selon le modèle d'architecture logicielle MVC, entièrement fluide (*responsive*) s'adaptant automatiquement aux formats smartphones et tablettes graphiques.

Partie 2 : Spécifications technique

1. Spécifiez les technologies que vous avez utilisé en justifiant les conditions d'utilisation et pourquoi le choix de ses éléments

PHP : L'utilisation de PHP natif nous a permis de structurer le code selon le modèle **MVC (Modèle-Vue-Contrôleur)**. Cela garantit une logique strict d'accès aux données (Modèles SQL), la logique métier (Contrôleurs) et l'affichage (Vues HTML/CSS), facilitant ainsi la maintenance future par d'autres développeurs.

MySQL & PDO : Justification : L'accès à la base de données est entièrement sécurisé via l'extension **PDO**. L'utilisation systématique de **requêtes préparées** (`$pdo->prepare()`) immunise l'application contre les failles de sécurité de type *Injection SQL*.

JSON Alternatif : Le format NoSQL orienté documents (géré via des structures JSON en PHP ou MongoDB) permet de stocker des historiques de logs ou de comportements d'achat sans schéma fixe.

Bootstrap 5 & CSS3 : Pour l'activité de Julie & José, la compatibilité mobile est indispensable (prise de commande en mobilité). Bootstrap intègre une grille fluide qui permet un rendu automatiquement **responsive**.

JavaScript : L'utilisation de JavaScript (sans framework lourd) a été privilégiée pour concevoir le module de **filtrage dynamique de la carte gastronomique**. En interceptant les événements sur les filtres, le script modifie directement le style CSS des cartes en tâche de fond. Le client obtient son résultat instantanément **sans rechargement de la page**.

Xamp : Il permet de simuler un serveur de production directement sur l'ordinateur de développement. En modifiant les directives d'accès dans la configuration d'Apache (Require all granted), XAMPP nous a permis d'ouvrir l'accès réseau local pour **tester le comportement réel du site sur un smartphone physique**.

2. Comment avez-vous mis en place votre environnement de travail ? Justifiez vos choix. (README.md)

Architecture de l'environnement de développement

L'environnement repose sur une suite logicielle intégrée, complétée par des outils d'édition et de gestion de version :

- **Serveur Local (Stack Web)** : XAMPP.
- **Éditeur de Code (IDE)** : Visual Studio Code (VS Code).
- **Gestionnaire de Version** : Git & plateforme GitHub.
- **IA** : Gemini.

3. Énumérez les mécanismes de sécurité que vous avez mis en place, aussi bien sur vos formulaires que sur les composants front-end ainsi que back-end.

Sécurisation des Formulaires

Validation des données (Côté Serveur & Client) : * **Côté client** : Utilisation des attributs HTML5 comme required, type="email", ou maxlength="150" pour guider l'utilisateur et bloquer les erreurs évidentes avant l'envoi.

Côté serveur : Nettoyage systématique des données reçues en PHP avec `filter_var()` et des filtres spécifiques comme `filter_var($_POST['email'], FILTER_SANITIZE_EMAIL)`. On ne fait jamais confiance aux données du navigateur.

Protection contre les attaques CSRF (Cross-Site Request Forgery) : * Mise en place d'un **jeton CSRF** (un token unique et aléatoire généré en session PHP).

Composants Front-end

Protection contre les failles XSS (Cross-Site Scripting) : * Lors de l'affichage de données provenant des utilisateurs (comme le prénom d'un membre ou un avis sur un plat), les données sont systématiquement échappées à l'aide de la fonction PHP `htmlspecialchars()`.

En-têtes de sécurité HTTP (Security Headers) .

Composants Back-end & Base de données

Protection contre les Injections SQL :

Utilisation exclusive de l'extension **PDO** avec des **requêtes préparées** (comme `$pdo->prepare($sql)` et `$stmt->execute(...)`). Les données utilisateurs ne sont jamais concaténées directement dans la requête SQL.

Hachage robuste des mots de passe :

Les mots de passe ne sont **jamais** stockés en clair. Utilisation de la fonction native de PHP `password_hash($password, PASSWORD_DEFAULT)`.

Gestion stricte des Rôles et Autorisations (RBAC) :

Mise en place d'une vérification systématique des privilèges via la colonne `role_id` (Admin, Modérateur, Client). Si un utilisateur tente d'accéder directement à une page d'administration en tapant l'URL, le script PHP vérifie sa session et le redirige immédiatement s'il n'a pas le rôle requis.

Gestion sécurisée des Sessions :

Utilisation de `session_start()` combiné avec des configurations sécurisées pour les cookies de session.

4. Décrivez une veille technologique que vous avez effectuée, sur les vulnérabilités de sécurité.

Ma veille sur l'OWASP m'a confirmé que les fonctions de hachage obsolètes (comme MD5 ou SHA1) sont aujourd'hui facilement piratables.

J'ai donc appliqué la recommandation actuelle de l'OWASP en utilisant `password_hash()` avec l'algorithme robuste **Bcrypt** pour protéger les mots de passe.

Suite à la lecture d'alertes sur des failles de serveurs locaux, j'ai veillé à utiliser une version récente et stable de **XAMPP** (embarquant PHP 8+ et MariaDB 10+) où les failles critiques passées ont été corrigées.

1. **Décrivez une situation de travail ayant nécessité une recherche durant le projet à partir de site anglophone. N'oubliez pas de citer la source**

La recherche sur un site anglophone

Pour comprendre pourquoi PHP masquait l'erreur, j'ai fait des recherches en anglais, car la communauté de développeurs y est beaucoup plus large. Je me suis rendu sur le site **Stack Overflow**, la référence mondiale d'entraide pour les programmeurs.

Les développeurs anglophones expliquaient que par défaut, sur les versions récentes de PHP/XAMPP, les erreurs PDO (liaison base de données) peuvent être configurées pour rester "silencieuses". Pour forcer PHP à cracher l'erreur à l'écran, il fallait ajouter une option spécifique (`PDO::ATTR_ERRMODE => PDO::ERRMODE_EXCEPTION`) lors de la création de la connexion.

2. **Mentionnez l'extrait du site anglophone qui vous a aidé dans la question précédente en effectuant une traduction en français.**

Par défaut, PDO fonctionne en mode silencieux (`PDO::ERRMODE_SILENT`). Si une erreur SQL survient, il ne lèvera aucune exception visible, ce qui se traduit par une page blanche ou une panne non gérée. Pour corriger cela, vous devez configurer explicitement PDO pour qu'il signale les erreurs en définissant l'attribut du mode d'erreur lors de l'initialisation :

Partie 4 : Informations complémentaires

1. **Autres ressources**

2. **Informations complémentaires**

Utilisation de Gemini tout au long du projet (gain de temps, et ça m'a beaucoup aidé il s'agit de mon premier projet d'envergure).